

Iowa State University

List of Information Gathered:

<https://status.it.iastate.edu/>

Using viewdns.info I was able to find subdomains for iastate.edu and able to see the IP addresses for most of them except for one subdomain:

<http://10000hours.stuorg.iastate.edu/>

When I tried to go to this subdomain it said:

Forbidden (You do not have permission to access / on this server)

I was able to find out that Iowa State's emails are serviced using Constant Contact. When I looked a little deeper using dnsdumpster.com, I found out that Constant Contact has open services from Cloudflare.

I also tried using certkit.io to investigate iastate.edu and found many more subdomains. Some certificates were issued by Amazon and others by Internet2.

When looking into the certificates from Amazon I found this one website for Iowa State:

<https://image.mail.shop.iastate.edu/>

The above also says Forbidden and that I do not have permission to access this website on this server. Furthermore, using the same certkit.io I was able to find a website that Iowa State is linked to named <https://www.woodcenter.org/>

Additionally, after using who.is to search the domain name iastate.edu I was able to find that there are administrative and technical contacts (key details I pulled from this were contact information):

+1 515-294-0323

Admin-contact@iastate.edu

+1 515-294-7498

Tech-contact@iastate.edu

With this search I also found the IP address 52.252.224.122 and using that I was able to netrange allocated to iastate which is 52.224.0.0 – 52.224.255.255. This was also verified using the terminal command “nslookup”.

I also found extra information about the server being used by iastate.edu:

Current Status

Status	Active
Server Type	Apache/2.4.58 (Ubuntu)
Page Title	Iowa State University
Meta Description	Iowa State University — where innovation is in the making. Experience hands-on learning, cutting-edge research, and endless opportunities for your future.
Meta Keywords	Not available
Most Recent Data	15 hours, 44 minutes ago

One Item useful to attack the organization and how to use it:

I noticed with all the above information that there are two key ways I could try to target Iowa State. One of them being the supply chain: Iowa State emails → Constant Contact → Cloudflare. Another being that the servers are running on Apache/2.4.58 (Ubuntu). Both of these would of course require further deep diving to find a critical point of failure or vulnerability but I think that it is doable if the assignment were not restricted to passive footprinting.

Items that I found that should not be public:

I do not think that some of the information above should be public such as the fact that I can lookup salaries for professors at a public university such as Iowa State. This being said, it is possible for such information to be used by attackers.

For example: Attacker finds a high ranked professor who is critical to the infrastructure of the university

OR

Attacker finds a staff member who is part of the university and handles the technology side of things such as maintenance (of services such as emails) or works in the financial services office.

With this information and publicly available salary information online for staff, an attacker could use this information and try to carry out a form of Social Engineering attack where he uses an “underpaid” staff to con him into doing something against Iowa State or perhaps unknowingly help the attacker by giving him more insights on the systems. This form of

social engineering could combine the psychology of humans with their current position at Iowa State and their salary. An attacker could try to identify someone at Iowa State who is vulnerable to giving into such patterns based on a multitude of factors.

Prompt used:

It says iastate.edu is associated with ip address 52.252.224.122 on the who.is website. How can I confirm this using a terminal command?

Response from AI:

To verify this yourself, you can use the DNS and WHOIS tools built into your terminal.

Since iastate.edu is the name and 52.252.224.122 is the address, you are performing two different checks: one to see if the name points to the address, and another to see who owns that address.

Step 1: Verify the DNS (Name to IP)

To see which IP address your computer thinks iastate.edu belongs to, use the nslookup or dig command.

Option A: nslookup (Windows, Mac, Linux)

Bash

```
nslookup iastate.edu
```

Option B: dig (Mac, Linux)

Bash

```
dig iastate.edu +short
```

What to look for: If the command returns 52.252.224.122, then the domain is currently configured to point to that specific server.

Step 2: Verify the Owner (IP to Organization)

Even if the domain points to that IP, the IP itself might belong to a hosting provider (like Microsoft) rather than the university's internal server. To check this, use the whois command.

The Command:

Bash

```
whois 52.252.224.122
```

What you will likely see:

When you run this, look for the "OrgName" or "Organization" field. For this specific IP (52.252.224.122), you will likely see Microsoft Corporation (Azure).

Why Microsoft? Iowa State University, like many large institutions, hosts its main website on cloud infrastructure (Azure). So, while the website is Iowa State's, the physical hardware and the IP address belong to Microsoft.

Pushback from AI on any prompts:

None

US Bank

List of Information Gathered:

Using the nslookup command on my computer, I found out that the IP address for usbank.com is 170.135.184.254 and that their netrange is 170.0.0.0 – 170.255.255.255.

Additionally, while looking with who.is and subdomain finder tools I was able to also create a link with Akamai and Venafi. The website: qa1.akamai.venafi.usbank.com found with one of the footprinting tools was able to tell me that U.S.Bank utilizes Venafi for its certificate management and Akamai for its content delivery (network/security) services.

From the structure of this url it indicates that qa1.akamai.venafi.usbank.com is a Quality Assurance (QA) testing environment for U.S. Bank, which is most likely being used to test their integration between Akamai and Venafi.

Also with the help of subdomain finder tool I was able to find out that U.S.Bank uses jira.usbank.com as their portal for employees, contractors, and authorized users.

While I was unable to access the website on my own since I do not have their internal VPN or a specific configuration set up, I found that their IP address for this portal is 170.135.185.49 which is actually quite a unique finding. I also found a url with the subdomain finder named <https://image.email.usbank.com>, however, when I tried to access the url I was given an access denied error.

Another interesting finding I made was that image.email.usbank.com is a subdomain for U.S.Bank with an IP address of 2.22.251.10 which does not match up with the netrange of U.S.Bank. When I dugged further into this I realized that this IP address actually belongs to Akamai instead. This further confirmed the supply chain claim that I made earlier.

One Item useful to attack the organization and how to use it:

Since we were able to find out that U.S.Bank partners with Akamai and Venafi, we can again craft a much more polished social engineering attack on the organization. For example an attacker could pose an “Akamai Support Staff” using the information gathered by footprinting U.S.Bank and then use that to generate and craft a more extensive social engineering attack.

Items that I found that should not be public:

<https://test-developer.usbank.com> 166.78.85.241

The IP above belongs to Rackspace, which is a third party hosting provider. This means it is outside the bank. This being said, attackers could try to carry out a targeted DDoS attack to take out this development environment since it is more vulnerable and would also cost the bank money since the developers would be impacted.

Prompt used:

U.S.Bank has a netrange of 170.0.0.0 – 170.255.255.255 however one of their subdomains is image.email.usbank.com with an IP address of 2.22.251.10. Can you explain this to me and tell me if footprinting such information is important or just a waste of time?

AI Response:

This is a classic "aha!" moment in network footprinting. You've stumbled upon the difference between Owned Infrastructure and Third-Party Services.

To answer your first question: 2.22.251.10 is not a U.S. Bank server. It belongs to Akamai Technologies, one of the world's largest Content Delivery Networks (CDNs).

Why the IP Address "Doesn't Match"

When you see a subdomain like image.email.usbank.com pointing to an IP outside the company's official netrange, it usually happens for one of three reasons:

Content Delivery Networks (CDNs): U.S. Bank wants the images in their emails to load instantly for everyone. Instead of hosting those images on their own servers in Minneapolis, they pay Akamai to host them on "edge" servers all over the world.

SaaS (Software as a Service): Large companies rarely build their own email marketing platforms. They use services like Salesforce, Adobe, or Oracle. The subdomain email.usbank.com is likely "delegated" to a third-party provider's servers.

Cloud Mitigation: Services like Cloudflare or Akamai act as a "shield." By pointing their DNS to these IPs, the bank protects their actual internal servers from DDoS attacks.

Is Footprinting This Info a Waste of Time?

Absolutely not. In fact, for an attacker (or a penetration tester), this is often where the real work begins.

1. It Reveals the "Supply Chain"

By footprinting that IP, you just learned that U.S. Bank relies on Akamai. If an attacker finds a vulnerability in Akamai's service or a specific configuration error in how they handle images, they can potentially bypass U.S. Bank's own perimeter security.

2. Finding "Shadow IT"

Footprinting subdomains often uncovers forgotten or unpatched servers. While the main usbank.com site is likely a fortress, a random subdomain like test-internal.email.usbank.com might be running on an old, unpatched server that was set up for a marketing campaign three years ago and never taken down.

Strict Professor's Note: The "Netrange" Myth

Be careful with your assumption about the 170.0.0.0/8 range. While U.S. Bank may own a large portion of it, many "Legacy" Class A blocks (those starting with 170, 12, 56, etc.) were broken up and redistributed decades ago. Always verify the CIDR block in a WHOIS record to see exactly what they own versus what belongs to other companies.

Key Takeaway: Footprinting is about mapping the ecosystem, not just the headquarters. The further a service is from the "official" netrange, the more likely it is to be managed by a third party—and third parties are often the weakest link in the security chain.

Pushback from AI on any prompts:

None

City of Ames

List of Information Gathered:

Cityofames.org – IP address 52.247.170.120

When looking into the who.is for City of Ames and reverse DNS I was able to find out that it belongs to Microsoft (Azure). Same as the above situation for U.S.Bank, City of Ames uses a cloud based infrastructure and chooses not to host things on premises.

The list of subdomains for this were actually very short and only comprised of:

amescxms.cityofames.org 209.56.242.52

ameswpm.cityofames.org 209.56.242.53

ems.cityofames.org 209.56.242.59

energov.cityofames.org 209.56.242.49

extranet.cityofames.org 209.56.242.51

gis.cityofames.org 209.56.242.46

policies.cityofames.org 209.56.242.56

vpn.cityofames.org 209.56.242.36

webtrac.cityofames.org 209.56.242.55

Also when looking deeper I was able to find an administrative contact (James Lawler) who is a GIS specialist with his phone number 515-239-5278, along with two other contacts Lisa Mondt 515-239-5162 and Clemir Abbeg Coproski 515-239-5321.

One Item useful to attack the organization and how to use it:

<https://ames-egov.aspgov.com/Click2GovCX/index.html>

Since most people would need to go to the above link to pay for their utilities and water bills, I think this would be the most useful attack vector for adversaries. Not just for a basic attack but something like a credential harvesting attack that could compromise a user's details in many different ways. Another thing that the attacker could carry out is to craft a phishing email where the attacker convinces a user that his bills are overdue and could link a cloned version of the website above. If they are even able to catch a few people off guard (especially old aged people) then the attacker would gain credentials to use which they can further try to use to sign into other accounts.

Items that I found that should not be public:

<https://hub.arcgis.com/maps/>

While the above (and google maps / apple maps) is not critical and cannot be heavily misused, the above website would allow attackers to be able to kind of "physically" footprint the layout for the Ames Power Plants and other utility areas which could give them insights on certain attack vectors. It is designed for residents of Ames and users to get a general idea and understanding of the layout for further knowledge but if an attacker

wishes to, he could use this information to map out the location physically and use it to his advantage.

Prompt used:

None

Pushback from AI on any prompts:

None